

Automated onboarding and rotation of non-domain-joined AWS Windows local admin accounts

What the solution must do and how each requirement will be proven. No CyberArk component and no architecture is presumed.

Document control

Status	Draft, not baselined
Version	0.6
Requirements	28, of which 26 Must
Host placement	AWS DMZ, not domain-joined
Vault target	PAM Self-Hosted 14.2 / 14.6, plus SaaS variant
Blocking decisions	5

1. Scope

Windows servers in the AWS DMZ are built from an AMI carrying a hardcoded local administrator password. They are not joined to Active Directory. The replacement design in section 3 removes that password and generates a unique one per machine, then stores it in AWS Secrets Manager for direct retrieval. That fixes uniqueness. It leaves custody, brokering and recording unsolved.

Two network zones matter throughout. The in-scope instances run in the AWS DMZ. Management and security components deployed into AWS run in the AWS Secure Zone. Every requirement about placement and traffic direction turns on that split.

This document states requirements, not solutions.

In scope

- Windows Server instances in the AWS DMZ that are not domain-joined, across every AWS account, VPC and region in which they run
- The local account used for administrative access to those instances
- Build-time creation, onboarding, rotation, retrieval and session brokering
- New builds, and migration of the instances already running on the AMI password

Out of scope

- Domain-joined Windows servers
- Linux and container workloads, pending an open decision
- AWS IAM users, roles and root account management
- Credentials not tied to the local admin account
- End-user workstation privilege management

Platform context

The primary target is CyberArk PAM Self-Hosted 14.2, with 14.6 in view. A second variant covering a SaaS vault is produced alongside the primary design so the two can be compared and a later migration is not a redesign.

2. Glossary

Term	Meaning
Secret Zero	The first credential in a chain of trust. The problem this specification treats as central: whatever bootstraps the system must not remain a standing key to it.
ClientAPI	The automation layer holding the existing integration that retrieves credentials from CyberArk and launches sessions.
Non-domain-joined	A Windows host with no Active Directory membership, so no domain account is available for reconciliation.
AWS DMZ	The less trusted AWS network zone where the in-scope Windows instances run. Hosts here hold no standing route to the Vault and no credential for it.
AWS Secure Zone	The trusted AWS network zone where management and security components are permitted to run. Any CyberArk or automation component deployed into AWS sits here.
User data	The EC2 boot-time script. Readable from inside the running instance through the metadata service by any local process.
Idira	Current brand for the CyberArk identity security platform following the Palo Alto Networks acquisition.

3. The design under evaluation

The proposed pipeline is the starting point. Seven of its decisions carry forward and appear in section 4 as requirements in their own right: Terraform with user data as the build tool (REQ16), instance self-registration on boot with the Vault as the target (REQ17), the deliberate avoidance of SSM (REQ24), a central automation point, now constrained to the Secure Zone (REQ22, REQ23), a random password unique to each machine (REQ07), scheduled rotation, now extended to rotation on onboarding (REQ08, REQ09), and the credential-handling standard of suppression in logs and no value on a command line (REQ12). What follows is what does not carry forward.

Element	Position	Requirement
The password is stored in AWS Secrets Manager, one secret per machine	Fails. The Vault must be the authoritative store	REQ01
Users and applications retrieve from the console or CLI	Fails. No session isolation and no recording	REQ03
The automation that generates the password also stores it	Fails. The building system holds a working credential	REQ02
The local admin account is established from user data at boot	Exposure. User data is readable from inside the instance	REQ12
Secrets named winlocaladmin/<host-ip>	Not durable. IP addresses are recycled	Section 6

Element	Position	Requirement
Open choice between a central secret store and a per-account store	Carried forward as an open decision	Section 7

4. Requirements

Each requirement carries an identifier, a MoSCoW priority and an acceptance criterion. Every design decision must cite an identifier. Every requirement here is a property of the finished solution that someone can test. Instructions about how the design work is carried out are in section 8.

Credential custody and access

Ref	Priority	Requirement	Acceptance criterion
REQ 01	Must	The CyberArk Vault is the sole authoritative store for every in-scope local administrator credential. Any other store, including AWS Secrets Manager, is a downstream copy fed one way from the Vault and never a source of truth.	One Vault account object per in-scope instance, zero in-scope instances without one, and any secondary store demonstrably fed one way from the Vault.
REQ 02	Must	Once onboarding completes, nothing outside the Vault holds a credential that works: not the build pipeline, not AWS, not any person. Any transient artefact used to reach that state, whether a generated password, a key pair, a certificate or an IAM role, is unique to one instance and invalid afterwards.	The Secret Zero test in section 5 passes, and replay of a bootstrap artefact against a second instance fails.
REQ 03	Must	All interactive administrative access is brokered through CyberArk and recorded. Authorisation is enforced per team or application by policy, not by knowledge of a password.	No path exists by which a named user obtains the password outside a recorded session, and a user outside the owning group is denied with the denial recorded.
REQ 04	Must	Retrieval and session launch are invocable by ClientAPI through its existing CyberArk integration, with no change to ClientAPI.	ClientAPI launches a recorded session to a newly built instance with no change to ClientAPI.
REQ 05	Should	Where an application rather than a person needs the credential, retrieval requires no	One application retrieves with no credential in its configuration.

Ref	Priority	Requirement	Acceptance criterion
		secret embedded in the application.	
REQ 06	Must	A break-glass path exists for Vault or network unavailability. It is time-bound, individually attributable and raises an alert on use.	Documented, exercised during the pilot and confirmed to alert.

Credential lifecycle

Ref	Priority	Requirement	Acceptance criterion
REQ 07	Must	Every in-scope server holds a unique local administrator credential. No shared password across instances and none baked into the AMI.	A sample comparison shows no two credentials equal, and the AMI holds no credential.
REQ 08	Must	The value set at build is invalidated by rotation before the instance is released for use. An instance that has not reached a managed and rotated state within the agreed operational window is quarantined and alerted.	The build-time password fails authentication before release, and an instance held past the window is quarantined with an alert raised.
REQ 09	Must	Credentials rotate on a defined schedule once under management.	Platform policy applies the agreed period and the rotation report shows it running to schedule.
REQ 10	Must	Rotation is verified, and drift between the Vault and the target is detected and remediated. No domain account is available for reconciliation, so the design must work without one.	An out-of-band password change is detected and reconciled with no manual action.
REQ 11	Must	Rebuild, replacement, scale-out and termination are handled. Accounts for terminated instances are disposed of and not left failing rotation.	Terminating an instance clears its account within an agreed window, with no recurring failures.

Handling of secret material

Ref	Priority	Requirement	Acceptance criterion
REQ 12	Must	No credential exists in readable form outside the Vault at any point: not in EC2 user data, not in Terraform state or plan	User data retrieved from a running instance, a scan of state and logs, and a review

Ref	Priority	Requirement	Acceptance criterion
		output, not in automation job logs, not on a command line, and never in clear text in transit.	of one complete onboarding all find no credential material, with TLS and validated certificates on every hop.
REQ 13	Must	The automation authenticates to CyberArk without a long-lived static secret held in code, configuration, state or a pipeline variable.	No CyberArk password or API key exists in any of those locations.
REQ 14	Must	Blast radius is bounded to a single instance. Compromise of one host yields no credential for another, and no component holds credentials for the fleet at rest.	Threat cases T1 and T4 in section 5 pass.
REQ 15	Must	Retrieval, session start, session end and rotation events are exported to the organisation's logging and monitoring platform.	Events carry instance identifier, actor and outcome, within an agreed delay.

Build and onboarding

Ref	Priority	Requirement	Acceptance criterion
REQ 16	Must	Terraform remains the build tool and continues to create the instance and establish the initial local account.	Existing Terraform modules are extended and not rewritten in another tool.
REQ 17	Must	No human is involved in onboarding an instance to CyberArk. Onboarding is triggered by the build or by the instance itself, with no ticket, no manual safe creation, no manual account add and no approval gate anywhere in the path.	A build started outside working hours reaches a managed account with zero human actions.
REQ 18	Must	Safe placement, policy assignment and authorisation are derived from instance tags, and the mandatory tags are enforced at launch.	An instance carrying a new application tag lands in the correct location with correct access and no manual configuration, and an untagged instance is rejected or quarantined.
REQ 19	Must	The process fails closed. An instance that cannot be	An induced failure quarantines and alerts,

Ref	Priority	Requirement	Acceptance criterion
		onboarded is flagged, alerted and quarantined and not left in service, and failure of the onboarding path does not block instance builds.	and instances built during an induced outage are processed on recovery.
REQ 20	Must	Onboarding is idempotent. Retries and instance replacement do not create duplicate or orphaned account objects.	Three runs against one instance yield exactly one account object.

Platform and network

Ref	Priority	Requirement	Acceptance criterion
REQ 21	Must	In-scope instances run in the AWS DMZ and are not joined to Active Directory. Both are fixed. Joining them to a domain, or relocating them to a more trusted zone, is not an acceptable solution.	Constraint, confirmed with the cloud and network teams.
REQ 22	Must	Any CyberArk or automation component deployed into AWS sits in the AWS Secure Zone. No component holding Vault connectivity, a Vault credential or secret material runs in the DMZ.	A placement diagram naming every component and its zone, approved by the network and security teams.
REQ 23	Must	DMZ instances hold no standing route to the Vault and no credential for it. Management connections are initiated from the Secure Zone, and where an application in the DMZ must retrieve a secret the request terminates at a broker in the Secure Zone.	Tested from a DMZ instance: the Vault is unreachable, and any permitted retrieval resolves only to the Secure Zone broker.
REQ 24	Must	The design must not depend on SSM as a control channel and must not break ClientAPI's existing CyberArk integration. The connection method used to reach the instance is a design choice, justified against REQ04 and the zone rules.	The chosen channel is stated with its reason, REQ04 still passes, and no SSM dependency exists.

Constraints on the solution

Ref	Priority	Requirement	Acceptance criterion
REQ 25	Must	The design introduces no duplication of function. Where a product already in place	A capability map shows one product per function, with any

Ref	Priority	Requirement	Acceptance criterion
		provides a capability, the design does not add a second product that performs the same job.	overlap named and justified.
REQ 26	Must	No new licence tier, SKU or agent entitlement is introduced unless no compliant alternative exists, in which case the cost is quantified and approved before design sign-off.	A cost line covering licence and run cost appears in the design, within an agreed budget envelope.
REQ 27	Should	No routine manual task in steady state. Human effort is limited to exception handling.	The runbook contains no recurring scheduled manual step.
REQ 28	Must	On demand, the solution shows every in-scope instance, its managed state and its last successful rotation.	A single report satisfies a sample request without manual collation.

5. Threat model

Secret Zero is a goal, not a control, and can only be verified against a stated adversary. The Vault is the trusted core and is the only participant trusted to hold a credential at rest. Every other participant is a boundary to be tested, and each case below states what an adversary in that position must be left with.

ID	Adversary position	Required outcome
T1	Local administrator on one in-scope instance	No credential for any other instance, no Vault credential and no ability to onboard a rogue host.
T2	Read access to Terraform state, plan output or pipeline logs	No usable credential for any instance, past or present.
T3	Read access to an AMI, an EBS snapshot or a shared image	No credential.
T4	Compromise of the orchestration layer	No bulk exfiltration. The layer holds nothing at rest and cannot read the Vault at scale.
T5	AWS workload account administrator	Can reach instances by other means, which is accepted. Cannot read Vault-held credentials or history, and cannot suppress onboarding without detection. The AWS control plane holds identity and ciphertext only, never a standing password.
T6	Insider with legitimate CyberArk access	Cannot obtain a credential outside a recorded, attributed session.
T7	Interception between AWS and the Vault	No credential recoverable. Authenticated encryption on every hop.

ID	Adversary position	Required outcome
T8	Replay of a bootstrap artefact against a second instance	Fails. Bootstrap artefacts are single use and instance bound.
T9	A compromised DMZ instance probing the Secure Zone	Reaches no Vault, no onboarding component and no other instance's credential. The only permitted path is inbound management traffic the Secure Zone initiated.

Secret Zero test for REQ02

Take a fully onboarded instance. Attempt authentication using the password the build set, any bootstrap artefact such as a key pair and its encrypted password data, any value recoverable from pipeline logs, state or user data, and the credential baked into the source AMI. All must fail. Only a Vault retrieval succeeds.

6. Interfaces and data standards

Proposed, and to be confirmed against existing platform conventions.

Object naming

Object	Proposed standard	Rationale
Account object	EC2 instance ID	Immutable, unique and never recycled. The proposed design keys on host IP, and IP addresses are reassigned, so a stored credential would eventually point at an unrelated machine.
Addresses	Private DNS name or instance ID	Same reason.
Safe	Derived from environment and application tags by a fixed rule	Derivable with no lookup table, and keeps safe growth predictable.
Platform	A dedicated platform for Windows local accounts on non-domain-joined AWS hosts	Carries its own rotation and verification policy.
Username	One standard local admin name, defined once. Which account that is remains an open decision	Per-team names defeat platform-level policy and discovery. The proposed design uses a purpose-created account and does not address the built-in Administrator account.

Mandatory launch tags

Tag	Drives	Enforcement
role	Marks the instance in scope	Terraform module, plus a detective control for missing or false values

Tag	Drives	Enforcement
app-id	Safe name and owning group	Terraform module, plus drift detection
environment	Safe name and rotation policy	Terraform module, plus a preventive control at launch per REQ18
owner	Escalation contact on failure	Terraform module

Flows to be specified in the design

Flow	Initiated from	To	Port	Authentication
Rotation component to instance	Secure Zone	DMZ	To be defined by the rotation method	Vault-held credential
Onboarding automation to the Vault API	Secure Zone	Vault	443	Non-static per REQ13
Onboarding automation to AWS APIs	Secure Zone	AWS endpoints	443	IAM role, least privilege
Application credential retrieval	DMZ	Secure Zone broker, never the Vault	443	Non-static per REQ05, subject to REQ23
Session broker to instance	Secure Zone	DMZ	3389	Vault-held credential
Vault to logging platform	Internal	Logging platform	To be confirmed	Existing integration

7. Assumptions and open decisions

Everything the specification rests on but has not confirmed. Blocking items must be closed before the specification is baselined. Assumptions carry an AS reference because the design cites them.

ID	Item	Status	If wrong, or once decided
OD-1	Who consumes the credential. ClientAPI and human operators only, or applications as well.	Blocking	If applications need programmatic retrieval, a further component enters the design and REQ05 becomes a Must.
AS-04	The password the build sets never needs to be usable by a person or another system.	Blocking	If anyone needs it even once, REQ02 cannot be

ID	Item	Status	If wrong, or once decided met as written and must be formally relaxed.
AS-03	Instances are long-lived servers rather than short-lived auto-scaled capacity.	Blocking	Decides between discovery-driven and event-driven onboarding, and whether account disposal under REQ11 is routine or exceptional.
AS-10	The account in scope is the purpose-created local account the proposed design builds, not the built-in Administrator. The proposed design says nothing about the built-in account, so whether it is present, enabled, renamed or disabled by hardening is unknown.	Blocking	Decides more than naming. The platform mechanism that generates and encrypts a password at first boot applies only to the built-in Administrator, so any option relying on it exists only if that is the account being managed.
OD-2	Standing credential or ephemeral account. An access model that creates a local account for the duration of a session and removes it afterwards leaves no standing password to manage and no bootstrap credential to protect.	Blocking	It answers the underlying risk more directly than anything in this document and does not satisfy REQ01 or REQ02, which both assume a credential held in the Vault. Choosing it means rewriting those two requirements.
AS-01	ClientAPI's existing CyberArk integration is production grade and needs no change to serve these instances.	Assumed	REQ04 becomes development work, changing effort and timeline.
AS-02	A routed network path exists or is obtainable from the AWS Secure Zone to the Vault.	Assumed	Either a new path is needed or an in-cloud component becomes mandatory, changing the architecture and the cost case.
AS-05	Windows only, with Linux a later decision.	Assumed	A second platform, rotation path and key handling model are needed.
AS-06	The operational window in REQ08 and the rotation reporting period in REQ28	Closeable	Neither requirement is testable until the values exist.

ID	Item	Status	If wrong, or once decided
	will be agreed at design time.		
AS-07	Instances already running on the AMI password exist and are in scope for migration, count unknown.	Closeable	Migration becomes a project of its own, and the count sizes it.
AS-08	The AWS Secure Zone exists, permits management components to be deployed into it, and has a routed path to the Vault. The DMZ has no such path.	Assumed	If the Secure Zone cannot host these components, every AWS-resident option fails and rotation has to reach in from outside AWS.
AS-09	Zone boundaries are enforced by network controls rather than convention, and a DMZ host genuinely cannot reach the Vault today.	Assumed	REQ23 becomes a build task rather than a confirmation, adding scope.
OD-3	Whether AWS Secrets Manager stays in the design at all, and if so whether any downstream copy is centrally owned or held per account.	Closeable	The same choice flagged in the proposed design, now reframed around the Vault as source.
OD-4	Actual fleet size, peak launch rate and the regions in scope.	Closeable	Sizes capacity, licensing and the migration.
OD-5	Which AWS services are permitted under cloud governance.	Closeable	May remove options from the design before they are assessed.
OD-6	Budget envelope for REQ26, and whether any new SKU is acceptable at any price.	Closeable	Can decide the design on its own.

8. Design deliverables and definition of done

How the design work is carried out and what it produces. These are conditions on the deliverable rather than properties of the solution, which is why they carry no requirement identifier.

- Every design decision cites a requirement identifier from section 4, and a traceability matrix accompanies the design with no orphan decisions.
- No CyberArk component is presumed. Any part of the product set may be used, and each selection is justified against a requirement.
- Every product capability claim is validated against current CyberArk or Idira documentation, with a citation and the date checked. No claim is accepted without one.
- Options considered and set aside are recorded with the requirement each one fails, including the proposed pipeline in its present form.

- Licensing impact is stated per component, including any new SKU, tier or agent entitlement.
- Every network path the design requires is stated with its direction and initiating side, and any new firewall rule is listed with its justification and intended lifetime.
- A migration plan covers the instances already running on the AMI password, removal of that password from the image pipeline, and a rollback.

The specification is baselined when the five blocking items in section 7 are closed, the remaining assumptions are confirmed or corrected with an owner named against any left open, and the threat model is signed off by security. Requirement identifiers freeze at baseline.

The solution is done when every Must requirement has a demonstrated pass, the Secret Zero test in section 5 passes against a live build, and the existing population has been migrated with the hardcoded credential removed from the image pipeline.